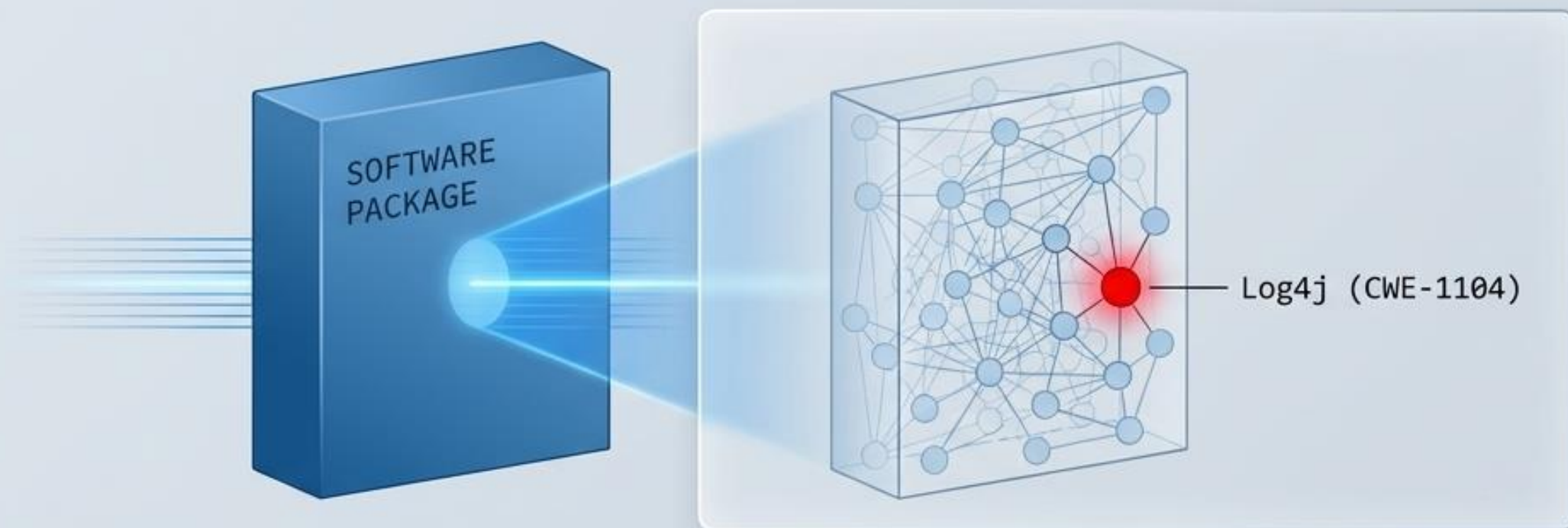


מפגש 9 - ששרת האספקה – המשך

ד"ר מיכאל טיבין



תלות טרנזיטיבית: אינך יכול לתקן את מה שאינך רואה



תסמונת Log4Shell

פגיעות Zero-day בספריית הרישום הנפוצה Log4j, אשר הייתה קבורה עמוק בתלויות של צד שלישי, רביעי וחמישי, מוסתרת מעיני הארגון.

וקטור תקיפה טריויאלי

ניצול מלא התאפשר על ידי הקלדת מחרוזת קצרה (`{jndi:ldap://...}`) בתיבות התחברות או חלונות צ'אט בלבד.

הלקח המרכזי

קוד צד ג' בלתי מתוחזק הוא החומר האפל של פיתוח תוכנה. נדרשת שקיפות מוחלטת באמצעות רשימת חומרים מלאה (SBOM).

תגובת המגן: מתודולוגיית ניהול סיכוני שרשרת אספקה (INCD)

מיסוד ארגוני (SCRM)

החלת תוכנית רשמית לניהול סיכוני שרשרת אספקה, המאושרת על ידי הנהלת הארגון ומתעדכנת שנתיית.

פונקציה ייעודית

מינוי גורם מקצועי האחראי ישירות על שרשרת האספקה (כפוף ל-CISO), בעל מומחיות בסייבר, מכרזים והתקשרויות.

ניהול מחזור חיים

בניית תהליך סדור משלב המכרז (אבטחת מידע כקריטריון סף), הוספת הספק, ועד לבקורות שוטפות.

מודיעין עסקי וסייבר

שילוב מודיעין איומים כחלק בלתי נפרד מהערכת החוסן של ספקים פוטנציאליים לפני תחילת העבודה.



סיווג ספקים ואכיפת מדיניות הגנה



זיהוי ספקי ליבה: ספק שפגיעה בו תשבית תהליכים עסקיים חיוניים בארגון.

אוטומציה ורציפות בקרת ספקים (מערכת 'יובל')

מסגרת עבודה - מערכת 'יובל'

דירוג עמידה כללי
ציון מצטיין

92%

רמת סיכון ספק ממוצעת
נמוכה

A+

סטטוס מערכת

פעיל

ספקים במאגר: +450

מערכת לאומית



פלטפורמה לאומית של מערך הסייבר ('יובל') להערכה ואבחון רמת הגנת המידע של ספקים.

שאלונים והתעדה



הספק ממלא שאלון המפיק ציון אוטומטי, ועובר בדיקות התעדה באמצעות בודקים מורשים.

מאגר ספקים בטוחים



הסתמכות על ספקים שקיבלו אקרדיטציה ממערך הסייבר הלאומי, לקיצור זמני רכש והוזלת עלויות.

אינטגרציית VRM/GRC



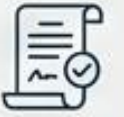
הטמעת כלים ארגוניים המאפשרים תמונת מצב הוליסטית של כלל הספקים, דירוג Benchmark, וניהול משימות לתיקון אוטומטי.

אסטרטגיית סיום וניתוק (Exit Strategy Plan)



ניתוק ממשקים

חיתוך מידי ומוחלט של כלל חיבורי הרשת, ה-VPN וההרשאות של הספק במערכות.



חגורת ביטחון חוזית

הגדרת תנאי הניתוק ונהלי חירום כבר בשלב חתימת החוזה הראשוני.



תגובה לאירוע (IR)

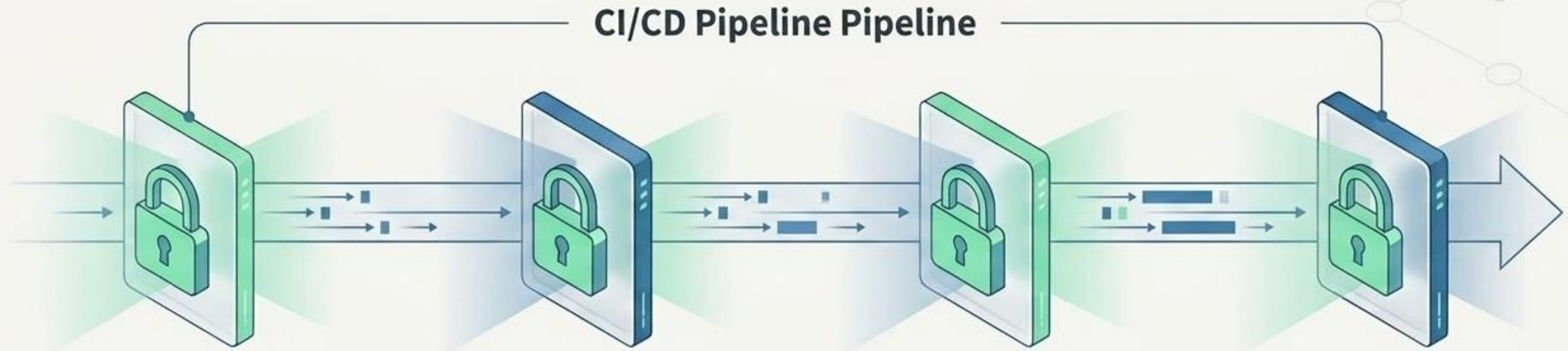
תוכנית מגירה המופעלת אוטומטית במקרה של חשד לפריצה או דלף מידע שמקורו בספק, להבטחת רציפות תפעולית.



השמדת מידע והשבת נכסים

עיגון הזכות לדרוש מהספק למחוק לצמיתות נתוני ארגון ולהשיב קניין רוחני.

התגובה ההנדסית: הקשחת שרשרת הפיתוח (DevSecOps)



סביבות בנייה סטריליות

בידוד סביבות הפיתוח
(Build environments)
(Build environments) ומניעת
הרשאות עודפות כפי שנוצלו
בתקיפות שרשרת קודמות.

בדיקות מקור (Verified Sources)

הסתמכות אך ורק על רכיבים
החתומים דיגיטלית ואומתו מול
מפתחות הצפנה מוכרים של
ספקים.

ניהול גרסאות (Version Pinning)

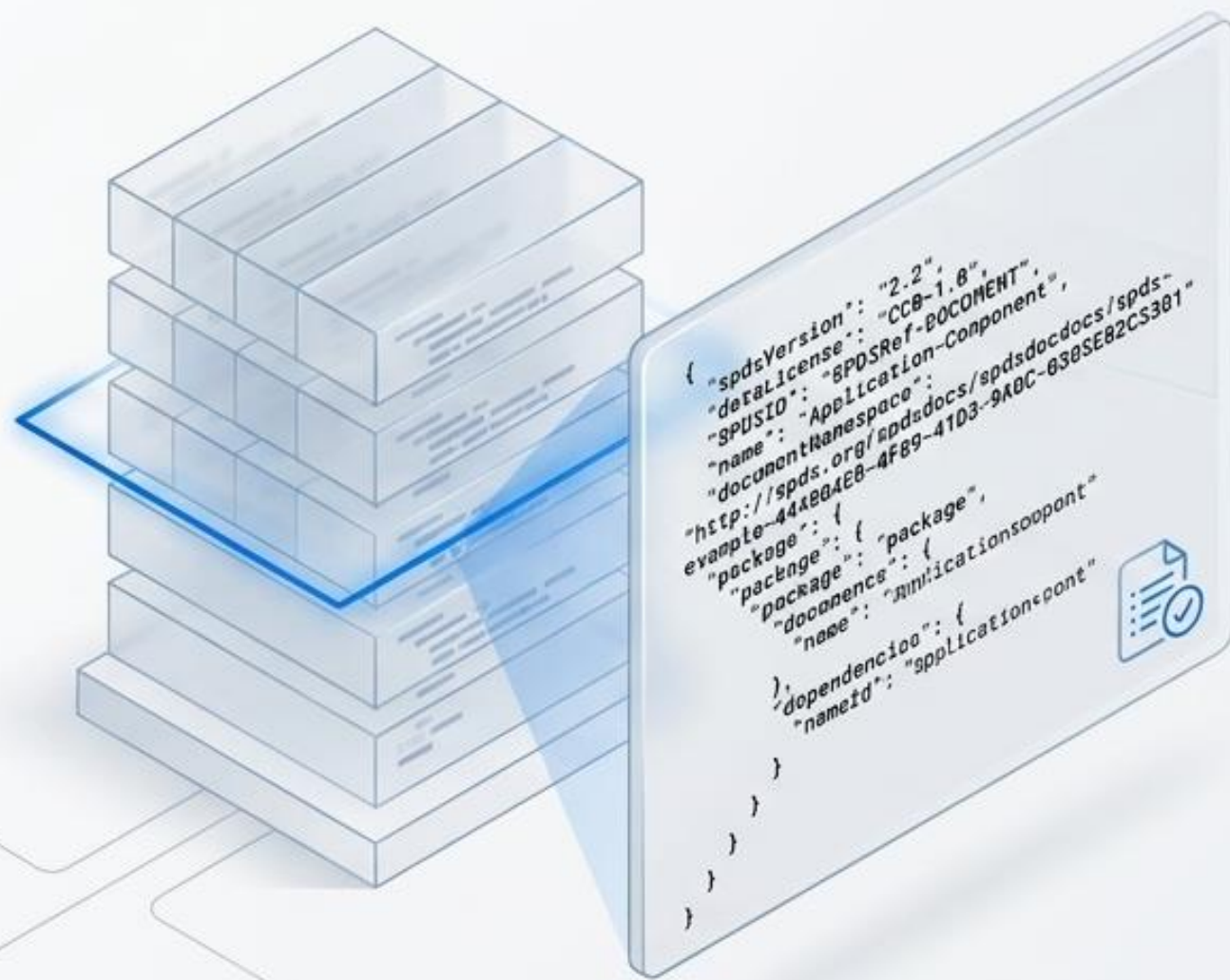
מניעת שדרוגים אוטומטיים
עיצורים של ספריות צד ג',
ואימות תקינות ידני של כל
עדכון תלות.

סריקה אוטומטית

סריקה מתמדת של הקוד
לאיתור סודות קשיחים
(Hardcoded secrets)
בטרם כניסתם לגרסה
(Commit).

שקיפות רדיקלית: מרכזיות ה-SBOM

ה-Living Inventory



מלאי דינמי מקיף (Software Bill of Materials)

רשימת מצאי המתעדכנת בכל בניית תוכנה, המספקת שקיפות מלאה גם לתלויות הטרנזיטיביות העמוקות ביותר.

קריאות מכונה

הפקה בפורמטים סטנדרטיים המאפשרים אינטגרציה קלה עם כלי סריקה אוטומטיים ללא תחזוקת גיליונות ידנית.

חיפוש באפס עיכוב (Zero-Latency)

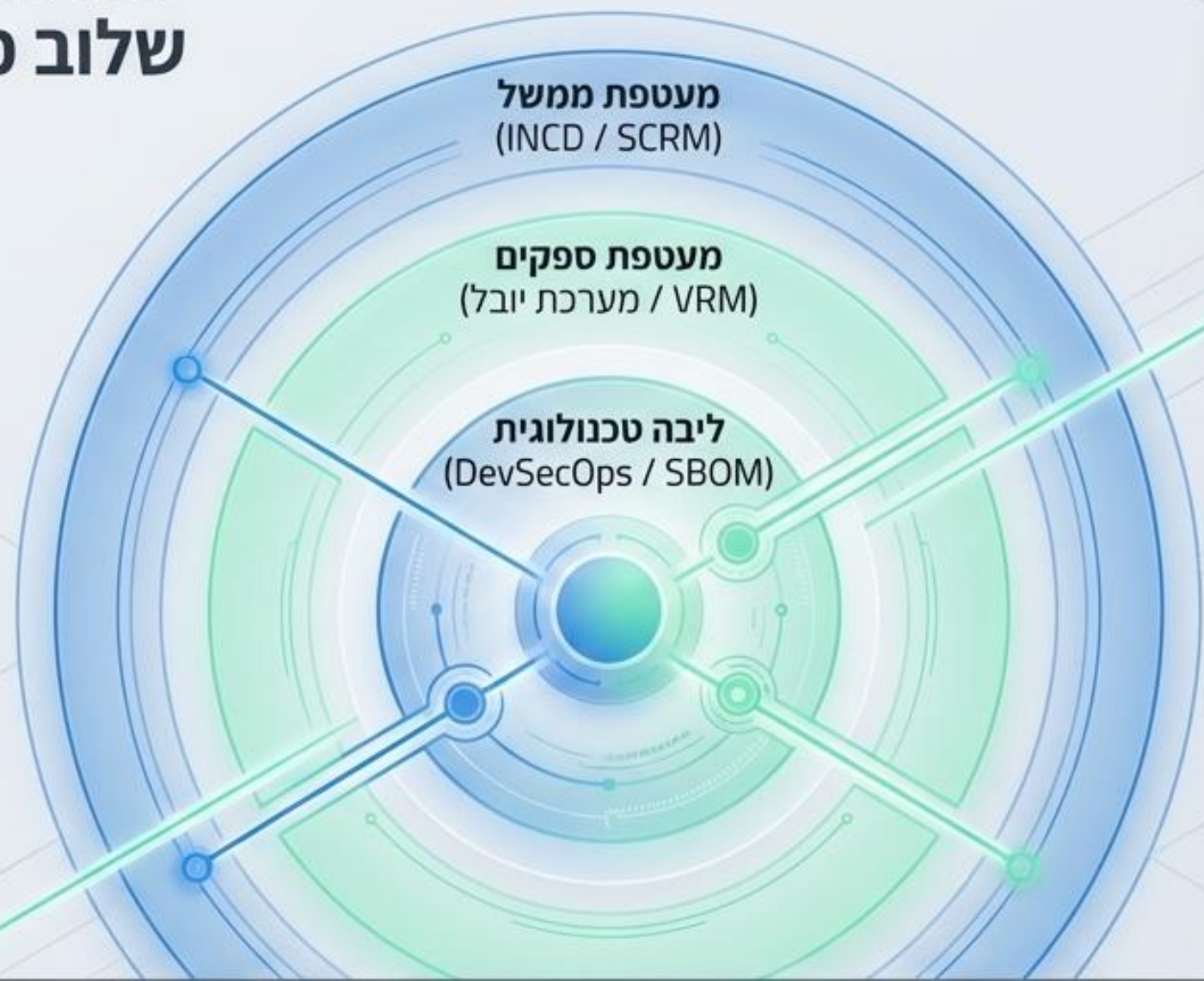
מאפשר לצוותי ה-SOC לאתר ספרייה פגיעה (Log4j) בכלל מערכות הארגון תוך שניות בודדות, ולא ימים.

Compliance as Code

אוטומציה המבטיחה עמידה ברגולציה ובדרישות אבטחה של גורמי הממשל ללא עומס על צוותי הפיתוח.

מערכת חיסונית אחודה: שלב ממשל, ספקים ופיתוח

- הביצוע: כלי הפיתוח מזהים.
- הסיכון: מערכות הספקים חוסמות.
- ההכונה: הממשל מכריח ליישם.



The Synthesis Insight

מדיניות ללא חשיפה טכנולוגית (SBOM) היא עיוורת. טכנולוגיה ללא אכיפת מדיניות (INCD) היא חסרת שיניים. חסינות אמיתית מפני איומי שרשרת דורשת סנכרון של כל השלושה.

Third Party Tools – Supply Chain ?



Security Breaches – HW – Flipper Zero



<https://www.youtube.com/watch?v=nLlp4wd0oXs>

SCRM – Supply Chain Risk Management - 2024





SCRM – Supply Chain Risk Management

ניהול סיכונים בשרשרת האספקה, המתמקד בזיהוי, הערכה וצמצום של סיכונים שעשויים להשפיע על זרימת הסחורות, השירותים או המידע בתוך שרשרת האספקה של הארגון

קשה להיות מוביל

CyberSecurity Companies 2021



Software supply chain risks



Compromised open-source
libraries and dependencies



Malware injection
during software builds



Unauthorized access to
source code repositories



Known vulnerabilities in third-
party tools and services



Exposed sensitive software
secrets in commercial
software binaries



Unvetted third-party
vendors

SCRM – Supply Chain Risk Management

- זיהוי סיכונים – ניתוח חולשות אפשריות בתשתיות, בתהליכים ובספקים .
- הערכת סיכונים – חישוב ההשפעה הפוטנציאלית של כל סיכון על רציפות התפעול והעסק .
- אסטרטגיות מניעה וצמצום – פיתוח תוכניות פעולה לחיזוק העמידות של שרשרת האספקה .
- ניטור שוטף – שימוש בכלי בקרה ואנליטיקה לזיהוי סיכונים בזמן אמת .
- תוכניות התאוששות – (BCP/DRP) יצירת מנגנונים להבטחת המשכיות עסקית במקרה של מתקפה או תקלה .



תרחישי סיכון עיקריים

פגיעה בזמינות - תחשבו על עננים

פגיעה בזמינות שירותי הארגון.

חשיפת מידע / פגיעה פיזית - תחשבו על מאגר ביאומטרי

חשיפת מידע רגיש של לקוחות.

נזק למוניטין / כלכלי

נזק למוניטין הארגון.

הפרת רגולציה – תחשבו על חברת תרופות

הפרת רגולציה וחשיפה לקנסות.

רגולציה ותקינה



הנחיות מערך הסייבר

הנחיות מערך הסייבר
הלאומי בישראל.



תקן ISO 27001

תקן בינלאומי לניהול
אבטחת מידע.

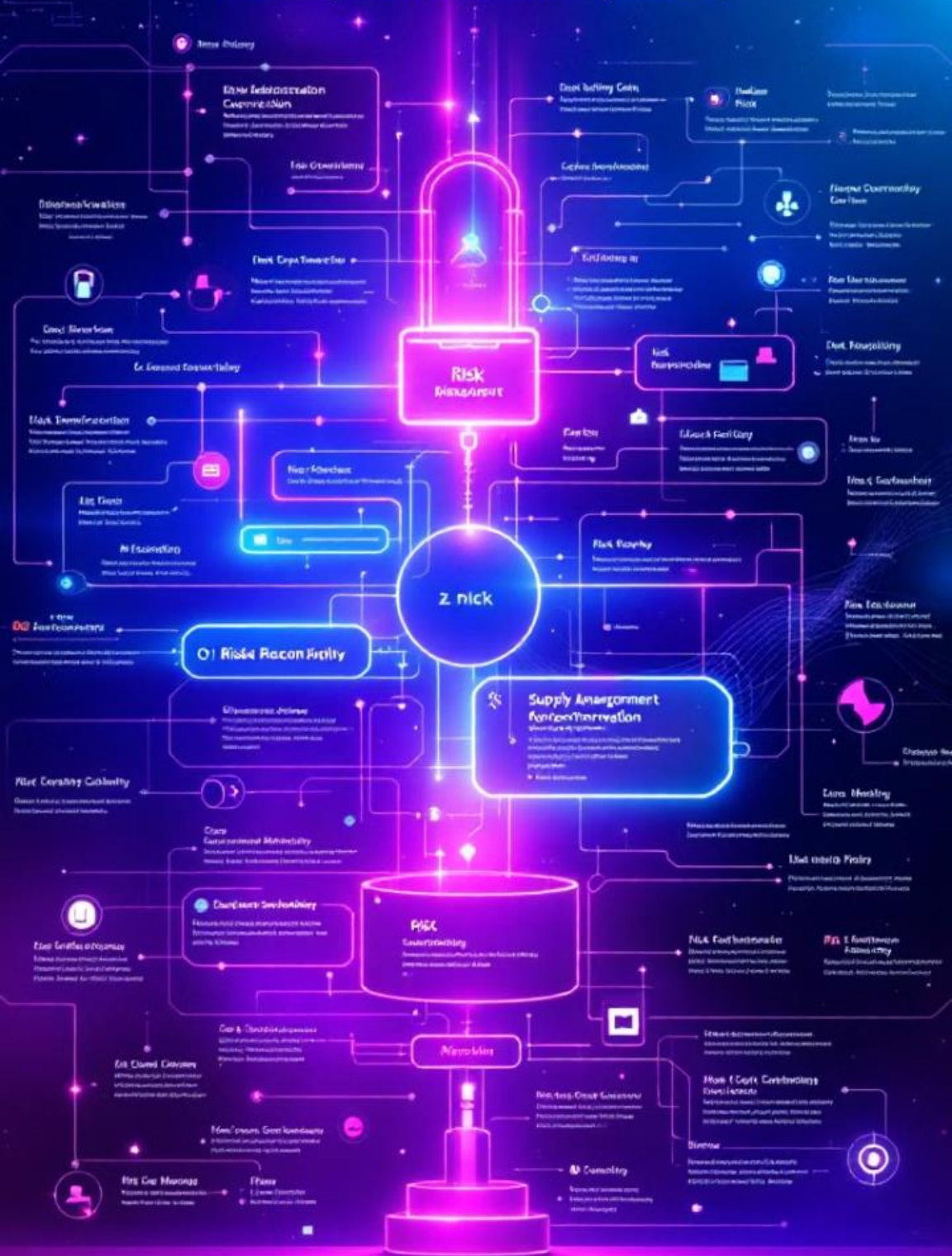


דרישות רגולטוריות

דרישות רגולטוריות ענפיות
ספציפיות.



Risk Management Protocols from IT on Cybersecurity



מיפוי ספקים

מיפוי ספקים ושירותים קריטיים.

הערכת סיכונים

הערכת סיכונים וזיהוי פערים.

יישום בקרות

יישום בקורות אבטחה מתאימות.

ניטור מתמשך

ניטור מתמשך ובחינת עמידות.

בקורות אבטחה מרכזיות

מדיניות אבטחה

1

הגדרת מדיניות אבטחת מידע לספקים כאילו הם חלק מהארגון

2

בדיקות רקע (כיום גם בהרבה חברות שתעבדו בהן)

בדיקות רקע וסינון ספקי (רקע פלילי, עובדים למאותמים, בעיות אבטחת מידע).

3

הגבלת גישה

הגבלת גישה למידע ומערכות החיוניות בלבד, כולל הנגשה פיזית לפעמים.

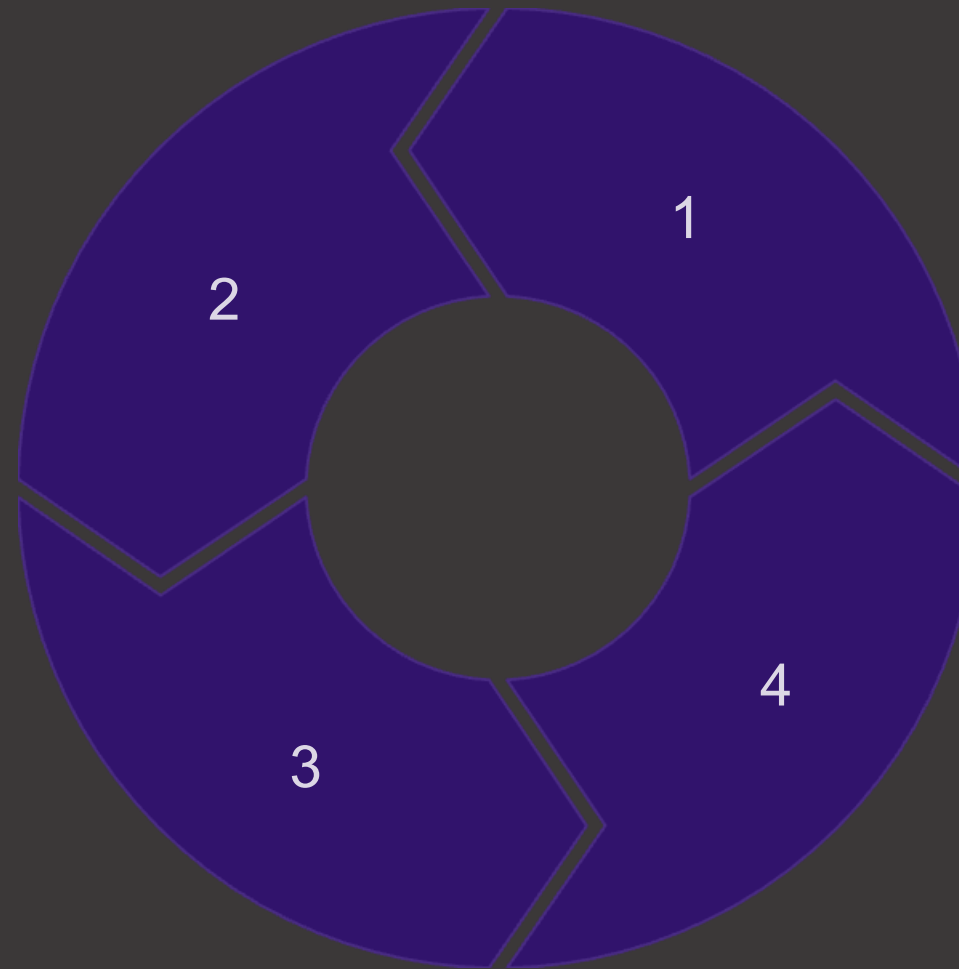
4

הצפנת מידע

הצפנת מידע רגיש בשרשרת האספקה, עם מפתח שלא חשוף לספק.



טכנולוגיות להגנת שרשרת האספקה



ניהול זהויות - Zero Trust / MFA
מערכות ניהול זהויות והרשאות.

ניהול אירועים

מערכות לניהול אירועי אבטחה (SIEM).

ניטור ובקרה

כלי ניטור ובקרה מתקדמים.

אבטחת ענן - WIZ

פתרונות אבטחה לענן ולמובייל.

תפקיד ההנהלה ביחס לספקי שירותים

1 אסטרטגיית אבטחת מוצרים גם לצד שלישי

1

2 הקצאת משאבים פיזיים, וירטואליים

2

3 מדדי ביצוע – KPI-ים – לפעמים יותר מוקשחים מפנים ארגוני

3

טיפול ופיתוח תרבות סייבר בארגון, והארגונים / הספקים הכפופים לו.

בניית חוסן ארגוני

חוסן ארגוני

1

שיתוף פעולה למטרה מסויימת, למשל ISO, FEDRAMP

2

למידה מתמדת (גם הרצאות וסדנאות בצד הספק, טרנדים)

3

שילוב ניהול סיכוני סייבר בתהליכים עסקיים. שיתוף פעולה עם ספקים להעלאת רמת האבטחה. למידה מתמדת והתאמה לאיומים משתנים.

תחקיר אירוע סייבר

מנהל הכספים מקבל הודעה מגורם אנונימי, אשר טוען כי עלה בידו לחדור למערכת הארגון ולשלוף מאגר מידע הכולל פרטים רבים וחסויים. הגורם מבקש 25 אלף דולר בביטקוין ובמידה ולא יקבל את הסכום בתוך 40 שעות, מאגר המידע יפורסם.



הארגון מפעיל נוהל אירוע סייבר



מה עושים ?



תחקיר אירוע סייבר

- מוקם צוות תגובה אשר כולל את מנכ"ל החברה, מנהל אבטחת המידע, מנמ"ר החברה, יועץ משפטי של החברה, מנהלת משאבי אנוש ואנשי צוות טכני מחברה ייעודית של ניהול תגובה לאירועי סייבר.
- מוכרז אירוע סייבר בארגון



חקירת אירוע

- במסגרת התחקור, הצוותים הטכניים בודקים מי התחבר לרשת ולמערכת, מי ניגש למוסדי נתונים, מי שלף מידע, ואף את התעבורה ברשת בתקופה האחרונה
- במסגרת כל הבדיקות לא נמצאה התחברות לרשת או גישה לבסיס נתונים שאינה מוכרת או תעבורת רשת חשודה



בדיקה מול ספקי צד שלישי

- לאחר בחינה מחודשת של היסטורית הגישה לבסיסי הנתונים ושליפתם, מתברר כי לפני מספר שנים החברה נעזרה בספק חיצוני לצורך פיתוח תוכנה באחת המערכות ובמסגרת הפיתוח ולצורך בדיקת המערכת עם נתוני אמת, העבירה החברה בסיס נתונים לספק
- עם זאת, מבדיקה עם ספק הפיתוח עולה כי הוא אינו מכיר מתקפת סייבר כלל



בדיקה מול ספקי צד שלישי - המשך

- אולם, בהמשך התחקור עולה כי ספק הפיתוח העסיק קבלן (גורם צד ג נוסף) מיקור חוץ לצורך הפיתוח, אשר קיבל לידו את בסיס הנתונים ואצלו מסתבר בוצעה מתקפת הסייבר ודרכו דלף המאגר..



מסקנות ולקחים

- לוודא כי הארגון הגדיר ויישם מדיניות הערכת סיכונים בשרשרת - SCRM – Supply Chain Risk Management האספקה
- ודא כי מיפוי ספקים שנערך כולל את דירוגם על פי רמת רגישות המידע אילו הם נחשפים
- במסגרת הסכם התקשרות, עיגון דרישות לעמידה בתקני אבטחת מידע מחמירים, לרבות ביצוע סקר ספק בטרם ביצוע התקשרות
- ביצוע ביקורות בחצרות הספק
- דרישה מהספק לעבור מבדקי חדירה
- יישום מדיניות סיום התקשרות עם ספק
- קיום תרגילים תגובה לאירועי סייבר
- שילוב הספק בתרגילי תגובה לאירועי סייבר.



Q & A